LITERATURE SURVEY

Trust-Aware Agentic AI for Autonomous Cyber Incident Response and Resilient Recovery

Project ID	Course	Review
221	UE24CS320A – Capstone Project	Phase-I · Review-2
Project Guide	**Institution**	**Survey focus**
Dr. Geetha Dayalan	PES University	LLM-based response planning and CTI

Prepared by: Abhirama H Y · SRN: PES2UG24CS023

Scope of This Survey

This document reviews two recent peer-reviewed papers on LLM-driven incident response. The first (Hammar et al., NDSS 2026) addresses how an LLM can plan response and recovery actions with a controlled risk of hallucination. The second (Tellache et al., IEEE GLOBECOM 2025) addresses how cyber threat intelligence (CTI) can be retrieved and fused into an LLM so that alerts are enriched and response actions are grounded. Together they cover two components of the proposed system: the response and recovery planner, and the CTI enrichment stage. Each paper is reviewed under the same headings, followed by a comparative analysis, the research gaps that remain, and references.

Paper 1 · Incident Response Planning with a Lightweight LLM

Research Paper Under Review

"Incident Response Planning Using a Lightweight Large Language Model with Reduced Hallucination"

Authors: Kim Hammar, Tansu Alpcan (University of Melbourne), and Emil C. Lupu (Imperial College London)

Publication: Network and Distributed System Security (NDSS) Symposium 2026, San Diego, USA, 23–27 February 2026

DOI: 10.14722/ndss.2026.240358

Open-access PDF: ndss-symposium.org/wp-content/uploads/2026-f358-paper.pdf

Abstract of the Survey

This survey reviews an NDSS 2026 paper that turns an LLM into a decision-support planner for incident response. Instead of trusting the first action a frontier model suggests, the authors fine-tune a small open model, ground it with threat intelligence, and select among several candidate actions by simulating their outcomes. The work is directly relevant to the capstone because it treats response as a recovery-time minimisation problem and tries to bound unreliable LLM output. It does not, however, reason about whether the evidence, assets or backups used during recovery are trustworthy, which is the gap the proposed Trust-Conditioned Recovery Planning (TCRP) targets.

1. Problem Addressed

Incident response is still largely manual and depends on scarce expert time. The authors cite a report that organisations need about 73 days on average to respond to and recover from an incident. Playbooks are the usual aid, but they must be configured by experts, are hard to keep aligned with changing threats and infrastructure, and tend to describe generic steps rather than commands that can be executed on a specific system.

Recent LLM-based approaches try to fill this gap, but most rely on prompt-engineering a frontier model through an external API. That is costly, creates a dependence on a provider, and exposes the operator to hallucination: the model may propose an action that sounds plausible but does nothing for the incident at hand. The paper therefore asks how an LLM can be used for response planning so that useful actions are chosen reliably, the model stays lightweight enough to run locally, and the chance of a hallucinated action can be reasoned about mathematically.

2. Proposed Methodology

Incident response is modelled as a stochastic shortest-path problem. The state of the response is a six-component recovery vector, each entry between 0 and 1: containment, assessment, preservation of forensic evidence, eviction of the attacker, hardening, and restoration of services. The goal state is all ones, and the objective is to reach it with the smallest accumulated action cost, which the paper calls the recovery time. The method then has three steps, split into an offline and an online phase.

Step	What the authors do
1. Instruction fine-tuning (offline)	A 14-billion-parameter model is fine-tuned on 68,000 incident–response pairs that include chain-of-thought explanations. Two instruction types are used: generate the next action, and predict the current response state (for example, whether the attack is contained or evidence is preserved).
2. Retrieval-augmented generation (online)	Indicators of compromise such as hostnames and vulnerability identifiers are extracted from the logs and used to query external threat-intelligence sources. The retrieved text is appended to the logs before prompting, so the model can react to threats newer than its training data.
3. Lookahead planning (online)	At each step the model proposes N candidate actions. For every candidate it simulates M possible recovery trajectories and estimates the expected time to finish. The action with the shortest estimated time is chosen, which acts as a self-verification filter against actions that make no progress.

The authors also give a theory section. They define a hallucinated action as one that does not change the expected remaining recovery time, show a sufficient condition under which the planning step always picks a non-hallucinated action when one exists among the candidates, and use Hoeffding's inequality to bound the probability that all candidates are hallucinated. The bound can be made smaller by increasing the number of candidates, at the price of longer planning time.

3. Technologies and Algorithms Used

The base model is a distilled DeepSeek-R1 variant with 14 billion parameters, fine-tuned with low-rank adaptation and 4-bit quantisation so that it can run on commodity hardware. Training data starts from 500 instruction–answer pairs collected on a Docker-based testbed of 64 hosts, where scripted attacks such as scans, brute-force logins and known CVE exploits were run and Snort alerts were recorded. This seed set was expanded to 68,000 incidents using synthetic data generated by Gemini 2.5 Pro and OpenAI o3. Threat intelligence is retrieved through the AlienVault OTX API. Incidents are labelled with MITRE ATT&CK tactics, and the recovery stages follow the MITRE D3FEND taxonomy. The planning procedure is a Monte-Carlo style rollout in which the LLM itself acts as the simulator.

4. Key Findings and Results

Evaluation uses logs of 25 incidents drawn from four public datasets (CTU-Malware-2014, CIC-IDS-2017, AIT-IDS-V2-2022 and CSLE-IDS-2024), plus five false-positive cases. The main metric is recovery time, measured in discrete action units, together with the share of ineffective actions and failed recoveries. Results are averaged over five random seeds.

Observation	Reported result	Interpretation
Against frontier LLMs	Shortest average recovery time (13.46 versus 16.21 for Gemini 2.5 Pro, 17.09 for DeepSeek-R1 and 17.28 for o3); the paper headlines up to 22% shorter recovery.	A small fine-tuned model with planning can beat much larger general models on this task.
Fine-tuning effect	Action accuracy on a held-out set of 500 incidents rose from 0.16 to 0.89, while the F1 for action type moved only from 0.93 to 0.97.	Base models already know which type of action is needed; fine-tuning teaches the concrete style of response.

Observation	Reported result	Interpretation
Ablation study	Without fine-tuning the average recovery time rose from about 13 to about 25, without planning to about 21, and without retrieval to about 15.	Fine-tuning and planning matter most; retrieval gives a smaller gain.
Against PPO (reinforcement learning)	Comparable recovery time and failed-recovery rate on CAGE-2 and a network-intrusion simulation, with no incident-specific training.	Avoids the 10–20 minutes of training PPO needs per incident, at the cost of more inference time.
Hallucination analysis	Measured hallucination rates stayed below the theoretical bound, although the bound is loose. A larger M lowered the observed rate.	The guarantee is conservative and depends on assumptions that must be estimated.
Scalability	Planning time grows roughly linearly with N when candidates are scored one after another, and stays almost flat when run in parallel on several GPUs.	Extra candidates are affordable with parallel hardware.

The authors also release the 68,000-incident dataset, the fine-tuned model weights and their code, which makes the work reproducible.

5. Limitations and Research Gaps

The evaluation relies on benchmark logs and simulations, not on a live security operations centre, and the authors themselves state that human oversight is still needed for critical decisions. Recovery time is counted in abstract action units, not in minutes on real systems. The hallucination guarantee rests on assumptions about how well the LLM predicts the next state, and these quantities are unknown in practice. Part of the training data is synthetic and was produced by other LLMs, which may carry their biases.

For the capstone, the more important gaps are conceptual. A hallucinated action is defined only as one that makes no progress, so the method does not distinguish a useless action from an unsafe one. The recovery state tracks how far each stage has progressed but not whether the thing being restored is clean: the paper's own worked example ends with "restore from a trusted backup", yet nothing in the method decides which backup is trusted, how a compromise window affects that choice, or what happens when evidence is missing or tampered with. Threat intelligence from OTX is treated as reliable. The method is decision support, so it has no execution layer, no deterministic policy check and no post-recovery validation. The authors note that the state could be extended to dependency graphs, but they do not do so.

6. Relevance to the Proposed Capstone Project

The paper is a close technical reference for the Response Planner and Recovery Planner agents of the proposed system. Its formulation of recovery as a time-minimisation problem matches the MTTR objective of the project, and its six-stage state vector, which includes forensic preservation and eviction, is a useful template for tracking progress and for the validation stage. Its observation that LLM output is plausible but unreliable supports the project's design principle that plausibility is not authorisation. The datasets, including CTU-Malware-2014 with ransomware traces, and the use of the OTX API are candidates for the public-data part of the project's data plan, and the open-source model gives a low-cost baseline for the LLM-only comparison.

The capstone goes further in three respects. It makes the trust of assets, evidence and recovery points an explicit input through the Recovery Trust Score and the TRUSTED, UNCERTAIN and UNTRUSTED states. It replaces probabilistic self-verification with a deterministic policy gate that blocks actions whose target or recovery source violates a trust constraint. It plans restoration over a service-dependency graph and re-scores trust when new evidence arrives. These are project-specific extensions, not contributions of the reviewed paper.

7. Conclusion

Hammar, Alpcan and Lupu show that a lightweight, fine-tuned and retrieval-grounded LLM, combined with lookahead planning, can generate shorter and more reliable response plans than much larger general models, and they supply a formal argument for why planning reduces hallucination. The work establishes recovery time as a practical measure and supports using small local models. It leaves open the question of which assets and backups can be trusted during recovery and how an unsafe action should be blocked, which is where the trust-aware approach of this capstone begins.

Reference

[1] K. Hammar, T. Alpcan, and E. C. Lupu, “Incident Response Planning Using a Lightweight Large Language Model with Reduced Hallucination,” in Proc. Network and Distributed System Security (NDSS) Symposium, San Diego, CA, USA, Feb. 2026, doi: 10.14722/ndss.2026.240358.

Paper 2 · Leveraging LLMs and Cyber Threat Intelligence for Incident Response

Research Paper Under Review

"Advancing Autonomous Incident Response: Leveraging LLMs and Cyber Threat Intelligence"

Authors: Amine Tellache, Abdelaziz Amara Korba, Amdjed Mokhtari, Horea Moldovan, and Yacine Ghamri-Doudane (OODRIVE Trusted Cloud Solutions and L3i Lab, University of La Rochelle)

Publication: 2025 IEEE Global Communications Conference (GLOBECOM), Taipei, Taiwan, 8–12 December 2025, pp. 25–30

DOI: 10.1109/GLOBECOM59602.2025.11432623

Author-posted copy: arxiv.org/abs/2508.10677

Abstract of the Survey

This survey reviews an IEEE GLOBECOM 2025 paper that uses retrieval-augmented generation (RAG) to feed cyber threat intelligence into an LLM-based incident-response assistant. The system enriches SIEM alerts with indicator reputation and with passages from threat reports, then asks an LLM to write a response strategy grounded in that context. The paper is relevant to the capstone because it implements the CTI-to-response step that the proposed CTI Agent must perform. It treats the retrieved intelligence as reliable and stops at a text recommendation, so it does not address trust in the evidence or recovery from a compromise.

1. Problem Addressed

Security teams face alert fatigue: the paper quotes an average of about 4,484 alerts per day and close to three hours of manual triage daily, with many false positives. Enriching each alert with threat intelligence helps, but CTI is large, unstructured and spread across sources, so reading and correlating it by hand is slow and needs skilled staff. Generic playbooks add little for less experienced responders.

Existing LLM work in CTI mostly handles passive tasks such as summarising reports or mapping text to ATT&CK techniques. The authors ask how LLMs can take an active part in incident response by retrieving relevant intelligence for a live alert and turning it into a specific, actionable response, without the cost of fine-tuning a model every time new intelligence appears.

2. Proposed Methodology

The system takes a SIEM alert as input and works in two phases, retrieval and augmented generation. A hybrid retrieval mechanism combines a structured lookup with a semantic search, and a dual evaluation scheme judges the outputs.

Component	Description
Knowledge base	Public CTI reports on APT and criminal campaigns are converted from PDF to text, split into chunks, embedded with a transformer model and stored in a vector database. New reports can be added without retraining.
Standard (IOC) search	An IOC parser pulls domains, IP addresses, hashes and URLs from the alert. Each indicator is looked up through a threat-intelligence API (VirusTotal in the experiments) to obtain reputation, history and geolocation.
NLP-based search	An LLM first rewrites the raw alert, together with the IOC findings, into a fuller incident description. Cosine similarity between this text and the report chunks then retrieves the most relevant passages and links the alert to past campaigns.
Augmented generation	A final prompt combining the alert, the IOC results and the retrieved passages asks the LLM to explain the likely attack and propose a response strategy. The prompt tells the model not to answer if the context does not support it.
Dual evaluation	Other LLMs score each answer from 1 to 5 on answer relevance, context relevance and groundedness. A security expert then checks a subset to validate the automatic scores.

3. Technologies and Techniques Used

The generation model is GPT-4o. Evaluation judges are Mistral-large-2407, Llama-3.1-70B-Instruct and Llama-3.2-3B-Instruct. Reports are parsed with PyMuPDF and stored in a Chroma vector database, and the CTI corpus comes from the public APT collection of VX Underground. Real alerts were produced by the company's LogPoint SIEM. For simulated alerts the authors built a test environment on a Proxmox hypervisor with an ELK-based SIEM, Windows and Linux targets with Elastic Defend agents, and MITRE Caldera as the attack emulator, running adversary profiles mapped to ATT&CK techniques such as automated collection, exfiltration over a command-and-control channel, process injection and credential dumping.

4. Key Findings and Results

The system was tested on 100 real SIEM alerts collected between 10 August and 8 September 2024, and on 10 alerts generated from emulated attacks. Scores below are means on the 1–5 scale reported in the paper.

Metric	100 real alerts	10 simulated alerts	Expert (10 simulated)
Answer relevance	4.26 to 4.97 across the three judges	4.80 to 5.00	4.20
Groundedness	4.19 to 4.53	4.55 to 4.80	4.10
Context relevance (IOC lookup + CTI reports combined)	3.15 to 3.62	4.00 to 4.55	4.10

Answer relevance and groundedness were high on both sets. Context relevance was clearly lower on real alerts. The authors explain this by the presence of false positives, indicators missing from VirusTotal, and CTI reports that do not describe the campaign in question; when all alerts were true positives, context relevance rose from about 3 to about 4. They also found that the two retrieval sources, IOC lookup and report search, contribute complementary context. The expert's scores were close to the automatic ones, which the authors take as support for the LLM-based evaluation.

5. Limitations and Research Gaps

The evidence base is modest: ten simulated alerts, judged by one security expert from the authors' own organisation, and an automatic evaluation in which LLMs grade LLM output. The reported metrics measure the quality of the text, not operational outcomes. Although the paper says response latency is reduced, the evaluation section does not tabulate timing or recovery measures. Generation depends on a closed commercial model, and the knowledge base is limited to public APT reports from one repository. The authors state that when no relevant context is found, as with false positives, the system still produces a coherent answer that is not backed by the retrieved material. Adversarial robustness is listed as future work.

From the capstone's viewpoint, the larger gap is that retrieved intelligence is accepted at face value. The paper does not model how reliable a CTI source is, whether two sources agree, or what to do when evidence is poisoned, stale or absent. Its output is a written strategy with no execution layer, no policy check and no human-approval step. It also stops before recovery: it does not consider backups, restore order or whether restored systems are clean.

6. Relevance to the Proposed Capstone Project

The paper is directly relevant to the CTI Agent in the proposed framework, which collects indicators and reputation data and passes them to the incident-analysis stage. Its IOC extraction and enrichment pipeline, the combination of API lookups with a vector search over reports, and the groundedness metric are all reusable ideas. The test environment (SIEM, Windows and Linux targets, Caldera emulation mapped to ATT&CK) is a realistic pattern for the project's lab and for generating labelled attack telemetry. The finding that context is weak for false positives and unseen campaigns is a concrete example of the incomplete-evidence situation that the project wants to label UNCERTAIN instead of acting on.

The capstone adds what this paper leaves out. CTI results would feed the threat-free confidence and reinfection-risk inputs of the Recovery Trust Score, with source provenance and independence considered through the forensic and provenance confidence input. Missing or conflicting intelligence would lower trust and trigger additional validation or human approval, and any recommended action would pass a deterministic policy gate before execution. These mechanisms are proposed project components and are not part of the reviewed paper.

7. Conclusion

Tellache and co-authors show that combining IOC lookups with semantic retrieval over threat reports lets an LLM produce contextual, well-grounded response suggestions without per-update fine-tuning, and they propose a practical dual evaluation method. The study is useful evidence that CTI can be fused into automated response. It assumes the intelligence is trustworthy and covers only the analysis and recommendation stage, leaving trust assessment, safe execution and recovery to be addressed by the trust-aware approach of the capstone.

Reference

[2] A. Tellache, A. Amara Korba, A. Mokhtari, H. Moldovan, and Y. Ghamri-Doudane, “Advancing Autonomous Incident Response: Leveraging LLMs and Cyber Threat Intelligence,” in 2025 IEEE Global Communications Conference (GLOBECOM), Taipei, Taiwan, Dec. 2025, pp. 25–30, doi: 10.1109/GLOBECOM59602.2025.11432623. Preprint: arXiv:2508.10677.

Comparative Analysis of the Selected Papers

The two papers target different stages of the same pipeline. Paper 1 decides which actions to take and in what order, and Paper 2 supplies the threat context that those decisions depend on. The table compares them against the aspects that matter for a trust-aware recovery system.

Aspect	Paper 1 – Hammar et al. (NDSS 2026)	Paper 2 – Tellache et al. (GLOBECOM 2025)
Main goal	Plan response and recovery actions that minimise recovery time.	Enrich alerts with CTI and generate a grounded response strategy.
Core technique	Fine-tuned 14B LLM, RAG, lookahead planning over a recovery-state model.	Hybrid RAG: IOC API lookup plus vector search over CTI reports, then GPT-4o generation.
Use of CTI	OTX lookups on extracted indicators, appended to the prompt.	Central contribution: VirusTotal plus a report knowledge base.
Handling unreliable output	Candidate actions filtered by simulated outcomes; probabilistic bound on hallucination.	Prompt instructs the model to abstain without context; groundedness scored afterwards.
Data and evaluation	25 incidents from four public datasets, 5 false positives, plus CAGE-2 and an intrusion simulation.	100 real SIEM alerts and 10 emulated alerts; LLM judges plus one expert.
Metrics	Recovery time, ineffective actions, failed recoveries.	Answer relevance, context relevance, groundedness (1–5).
Headline result	Up to 22% shorter recovery than frontier LLMs; comparable to PPO.	High relevance and groundedness; context relevance weaker on real alerts.
Human oversight	Decision support; authors say humans are needed for critical decisions.	Expert used only for evaluation; no approval step.
Execution of actions	None; recommends actions.	None; produces a text strategy.
Backups, restore order, trust	Mentions restoring from a trusted backup but does not assess trust; dependency graphs noted as an extension.	Not addressed.
Main limitation	Benchmark and simulated evaluation; hallucination defined as no progress, not as unsafe.	Small expert evaluation; CTI assumed reliable; no operational metrics.

Taken together with the playbook-study and recovery-guidance surveys already in the repository, these papers cover automated planning and CTI enrichment. They agree that LLM output needs grounding, and each applies a different remedy: Paper 1 uses planning and self-verification, Paper 2 uses retrieval and abstention. Neither applies a hard constraint based on the trustworthiness of the evidence or the recovery source.

Identified Research Gaps

- **No trust assessment of recovery sources.** Neither paper decides whether a backup, asset or piece of evidence is safe to rely on after compromise. Hammar et al. refer to restoring from a trusted backup, but treat trust as given.
- **Hallucination is handled as ineffectiveness, not as safety.** Paper 1 defines a bad action as one that makes no progress and reduces its probability. An action that makes progress but violates a security or trust constraint is not blocked by either method.

- **Probabilistic filtering instead of a deterministic gate.** Both approaches reduce errors statistically. Neither enforces rules that can reject an action outright, nor requires human approval for high-impact steps.
- **CTI and evidence are assumed trustworthy.** Source reliability, independence, agreement between sources and tampering are not modelled, and missing context leads to coherent but ungrounded answers in Paper 2.
- **No explicit state for uncertainty.** Incomplete evidence is not mapped to a distinct state such as UNCERTAIN that would trigger extra validation.
- **Recovery ordering and business dependencies are not planned.** Paper 1 tracks stage progress only and notes dependency graphs as future work; Paper 2 does not reach recovery.
- **Evaluation focuses on speed or text quality.** There are no safety metrics such as contaminated-recovery rate, recovery-point selection accuracy, unsafe-action rate or residual compromise, and no re-scoring after recovery.
- **Trust is not dynamic.** Neither method recalculates a trust value when new telemetry, forensic findings or a revised compromise window arrive.

Overall Conclusion

Recent LLM-based incident-response research has made real progress on speed and on reducing unreliable output, and CTI retrieval has become a practical way to ground responses. The reviewed work also shows what is still missing: a way to judge what remains trustworthy after a compromise, a hard constraint that stops unsafe actions even when they look plausible, and evaluation that measures safety as well as time. These gaps justify the proposed Trust-Conditioned Recovery Planning mechanism, in which a Recovery Trust Score and trust states constrain agentic planning, a policy gate and human approval control execution, and recovery is validated and re-scored as evidence changes.

References

[1] K. Hammar, T. Alpcan, and E. C. Lupu, “Incident Response Planning Using a Lightweight Large Language Model with Reduced Hallucination,” in Proc. Network and Distributed System Security (NDSS) Symposium, San Diego, CA, USA, Feb. 2026, doi: 10.14722/ndss.2026.240358. Available: https://www.ndss-symposium.org/wp-content/uploads/2026-f358-paper.pdf

[2] A. Tellache, A. Amara Korba, A. Mokhtari, H. Moldovan, and Y. Ghamri-Doudane, “Advancing Autonomous Incident Response: Leveraging LLMs and Cyber Threat Intelligence,” in 2025 IEEE Global Communications Conference (GLOBECOM), Taipei, Taiwan, Dec. 2025, pp. 25–30, doi: 10.1109/GLOBECOM59602.2025.11432623. Preprint: https://arxiv.org/abs/2508.10677

Prepared for Capstone Project Phase-I · Review-1 by Abhirama H Y (PES2UG24CS023). This document surveys two research papers; it is not the complete project literature survey.